

Introduction to Cyber Security



Introduction

- What Is Information?
- What is Cyber Security?
- OSI Security Architecture
- Threat & Vulnerability
- Types of Cyber Attacks
- Types of Cyber Criminals
- Why Is Information Security Important?
- What Can We Do?

What Is Information?

- “Information is an asset which, like other important business assets, has value to an organization and consequently needs to be suitably protected”

BS ISO 27002:2005

- Information can be printed on paper, stored electronically, Shown on video, published on web, spoken in conversations etc.

What Is Information?

- Information can be created, stored, processed, transmitted, destroyed, lost and stolen.
- Whatever form the information takes, or means by which it is shared or stored, it should always be appropriately protected'.

(BS ISO 27002:2005)

The Cast of Characters

- **Alice** and **Bob**, who are pictured in Figure 1, are the Good guys.
- Occasionally we'll require additional good guys, such as Charlie and Dave.
- **Trudy**, pictured in Figure 2, is a generic bad "guy" who is trying to attack the system in some way.
- **Trudy** is an "**intruder**".
- **Alice, Bob, Trudy, and the rest of the gang need not be humans.**
- **For example**, one of many possible scenarios would have Alice as a laptop, Bob a server, and Trudy a human.



Figure 1



Figure 2

Alice's Online Bank

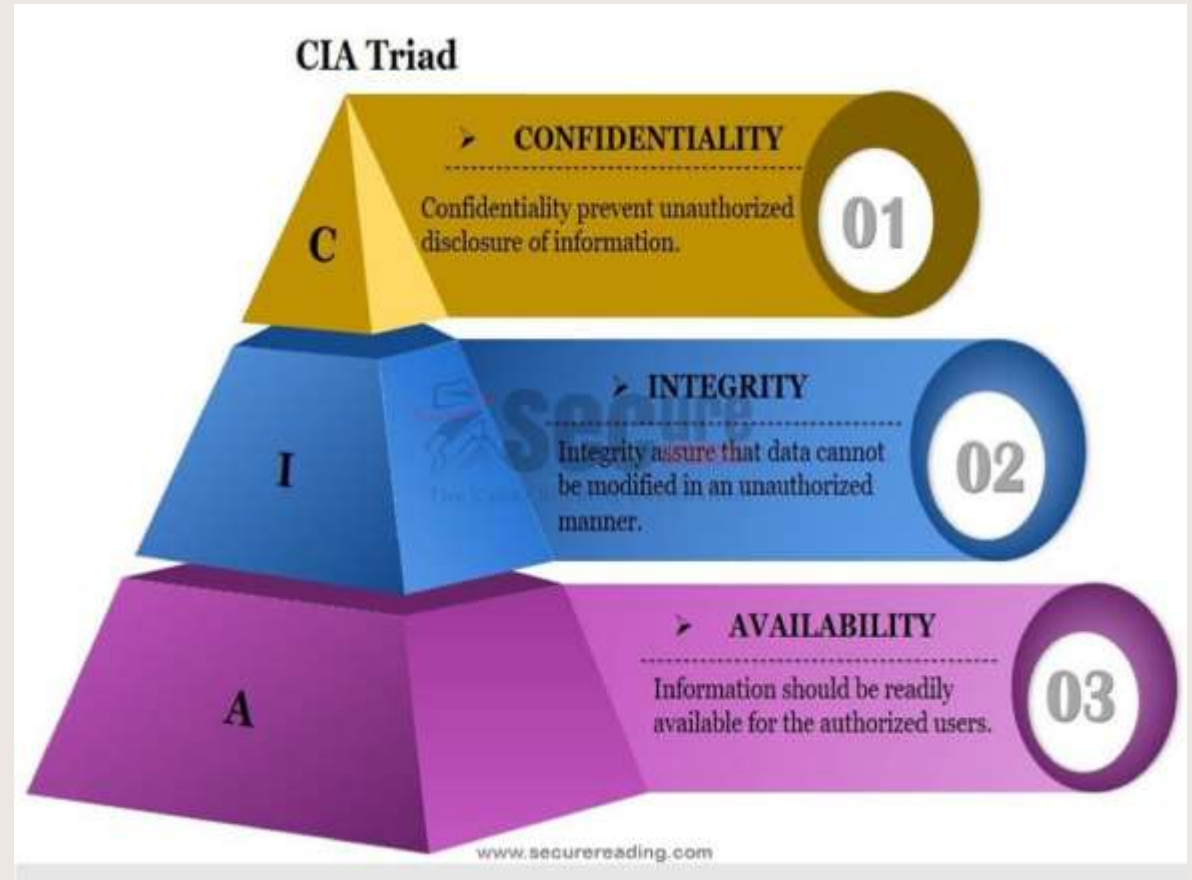
- Alice starts an online banking business, named Alice's Online Bank or AOB.
- **What are Alice's information security concerns?**
- If Bob is Alice's customer, **what are his information security concerns?**
- Are Bob's concerns the same as Alice's?
- If we look at AOB from Trudy's perspective, **what security vulnerabilities might we see?**

What is Cyber Security?

- Cybersecurity is the way to prevent servers, devices, electronic systems, and networks from digital attacks, and damage.

What is the Basic Principle of Security or CIA Triad?

- Three widely accepted concepts important to information (referred to as the “CIA Triad”):
 - Confidentiality
 - Integrity
 - Availability
- Includes Physical Security as well as Electronic



Confidentiality

- *Confidentiality* deals with preventing unauthorized reading of information.
- **For example:** confidentiality is maintained for a Bob's saving account, if Bob is able to view it, while unauthorized person Trudy is blocked from seeing it.
- Alice's Bank would also face legal problems if it failed to protect the confidentiality of such information.
- Bank account statements, personal information, credit card numbers, trade secrets, government documents are some examples of sensitive information.

Integrity

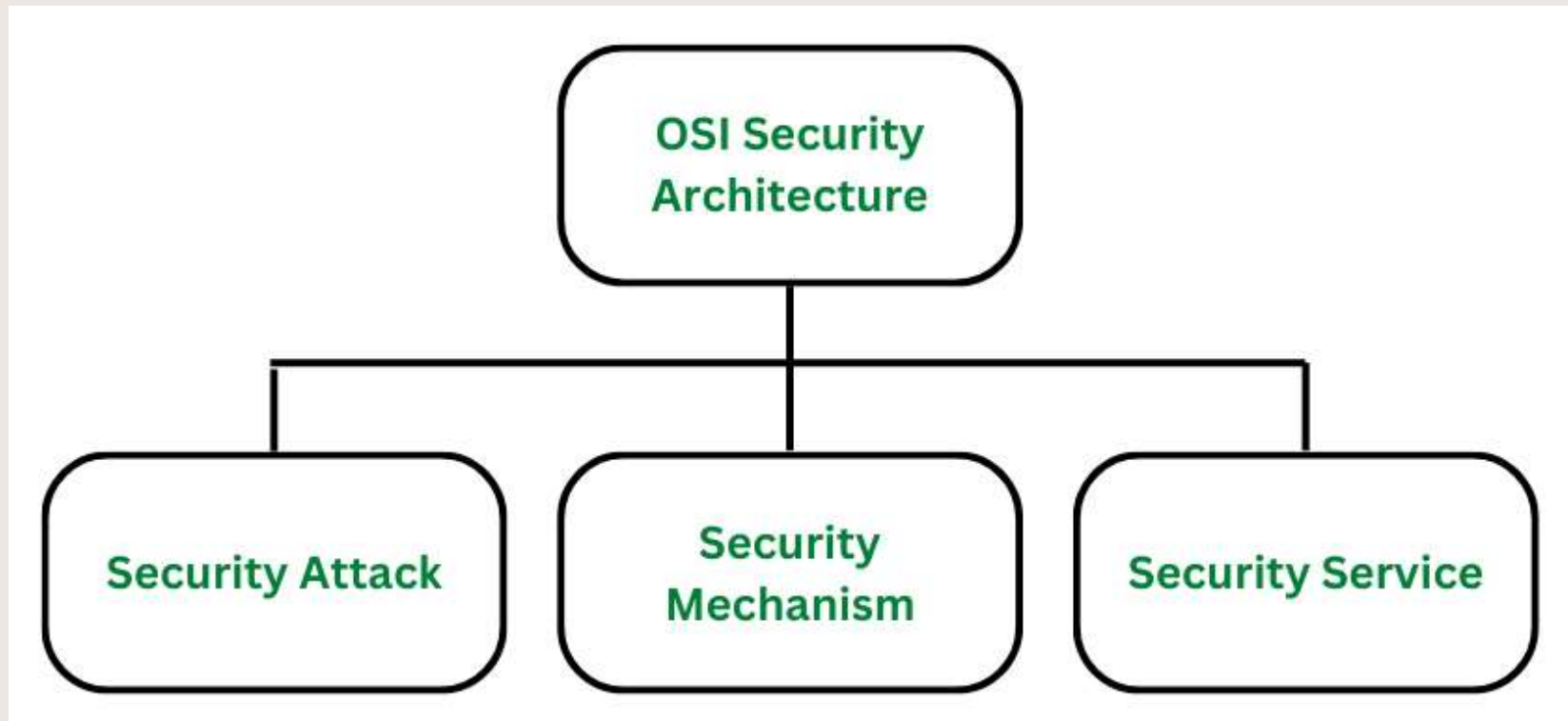
- **Integrity** deals with preventing unauthorized "writing" (i.e., changes to data).
- Alice's Bank must protect the integrity of account information to prevent Trudy from, say, increasing the balance in her account or changing the balance in Bob's account.
- **In the CIA triad**, integrity is maintained when the information remains unchanged during storage, transmission, and usage not involving modification to the information.
- **Example:** banks are more concerned about the integrity of financial records, with confidentiality having only second priority.
- Some bank account holders or depositors leave ATM receipts unchecked and hanging around after withdrawing cash.
- **This shows that confidentiality does not have the highest priority.**

Availability

- **Availability** is the situation where information is available when and where it is rightly needed.
- **Example:** Denial of service, or DoS, attacks try to reduce access to information. Rising in DoS attacks, data *availability* has become a fundamental issue in information security.
- Availability is an issue for both Alice's Bank and Bob in AOB is important. If Trudy has a complaint against Alice, or if she just wants to be malicious, she might attempt a denial of service attack on Alice's Online Bank.

OSI Security Architecture

- OSI Security Architecture is defined by the three concepts:

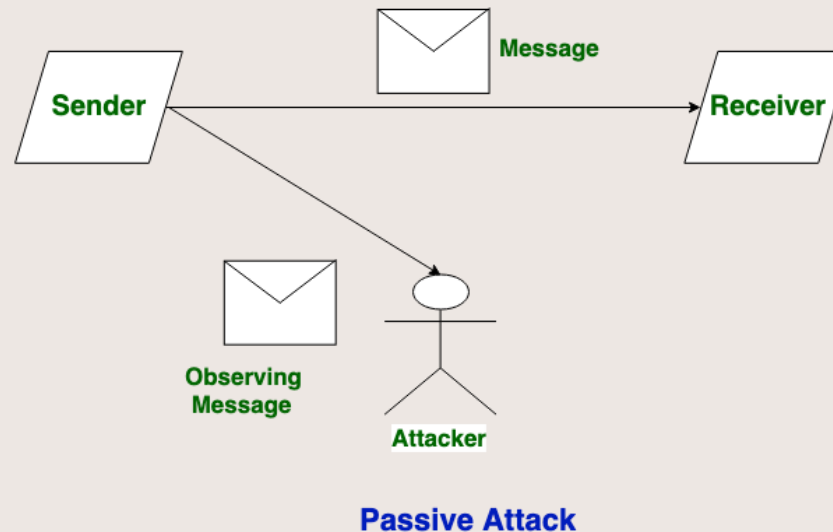


Security Attacks

- **A security attack** is an attempt by a person or entity to gain unauthorized access to disrupt or compromise the security of a system, network, or device.
- They are further classified into **2 sub-categories**:
 - **Passive Attack**
 - **Active Attack**

Security Attacks : Passive Attacks

- Passive Attacks are the type of attacks in which, the attacker observes the content of messages or copies the content of messages.
- Passive Attack is a danger to Confidentiality.
- Due to passive attack, there is no harm to the system.
- The most important thing is that In a passive attack, Victim does not get informed about the attack.
- **One way to prevent passive attacks is to encrypt the message/data**

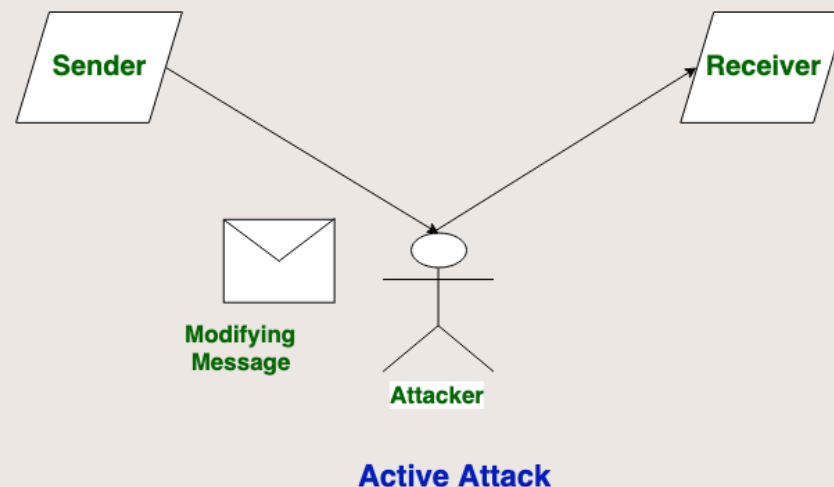


Security Attacks : Passive Attacks

- Passive attacks are further divided into two parts based on their behavior:
 - **Eavesdropping:** This involves the attacker intercepting and listening to communications between two or more parties without their knowledge or consent.
 - **Example:** packet sniffing, or man-in-the-middle attacks.
 - **Traffic analysis:** This involves the attacker analyzing network traffic patterns and metadata to gather information about the system, network, or device.
 - intruder can't read the message but only understand the pattern and length of encryption.
 - **Example:** network flow analysis, or protocol analysis

Security Attacks : Active Attacks

- Active attacks are the type of attacks in which, attacker efforts to change or modify the content of messages.
- Active Attack is dangerous to Integrity as well as availability. Due to active attack system is always damaged and System resources can be changed.
- The most important thing is that, In an active attack, Victim gets informed about the attack.
 - **Example:** Masquerade , Replay , Modification of Message, and Denial of service (DoS)



Security Attacks : Active Attacks

- **Masquerade:** This type of attack can involve the attacker using stolen or forged credentials, or manipulating authentication or authorization controls in some other way.
- **Replay** is a type of active attack in which the attacker intercepts a transmitted message through a passive channel and then maliciously replays or delays it at a later time.
- **Modification of Message** involves the attacker modifying the transmitted message.
- **Denial of service (DoS)** attacks involve the attacker sending a large volume of traffic to a system, network, or device in an attempt to overwhelm it and make it unavailable to legitimate users.

Security Mechanism

- The mechanism that is built to identify any breach of security or attack on the organization, is called a **security mechanism**.
- It provides **confidentiality, integrity, or availability**.

Example of Security Mechanism

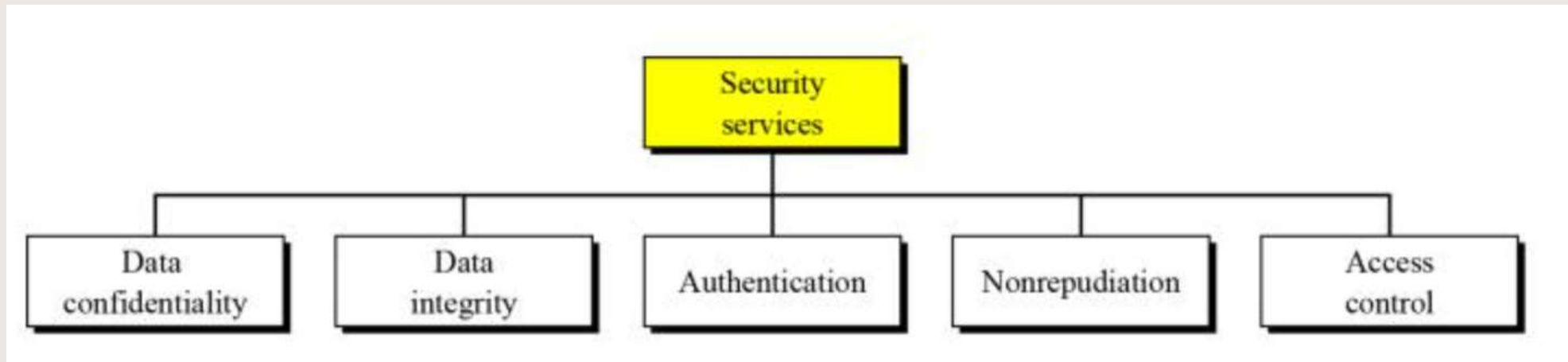
- **Encipherment (Encryption)** involves the use of algorithms to transform data into a form that can only be read by someone with the appropriate decryption key.
- **Digital signature** is a security mechanism that involves the use of cryptographic techniques to create a unique, verifiable identifier for a digital document or message, which can be used to ensure the authenticity and integrity of the document or message.
- **Traffic padding** is a technique used to add extra data to a network traffic stream in an attempt to vague the true content of the traffic and make it more difficult to analyze.
- **Routing control** allows the selection of specific physically secure routes for specific data transmission and enables routing changes, particularly when a gap in security is suspected.

Security Services

- **Security services** refer to the different services available for maintaining the security and safety of an organization.
- They help in preventing any potential risks to security.

Security Services Types

- Security services are divided into 5 types:



- **Confidentiality** - already discussed
- **Integrity** - already discussed
- **Authentication**
- **Access control**
- **Non- repudiation**

Security Services-Authentication

- **Authentication** is the mechanism to identify the user or system or the entity.
- It ensures the identity of the person trying to access the information.
- The authentication is mostly secured by using username and password.
- **Example:** Bob logs on to his computer, **how does Bob's computer determine that "Bob" is really Bob and not Trudy?**
- Bob logs into his account at Alice's Online Bank, **how does AOB know that "Bob" is really Bob, and not Trudy?**

Security Services- Non- repudiation

- **Non- repudiation:** involves the use of techniques to create a verifiable record of the origin and transmission of a message, which can be **used to prevent the sender from denying that they sent the message.**
- **How can we ensure nonrepudiation?**
- To provide nonrepudiation, system must provide evidence of communications and transactions that should involved the identities or credentials of each party so that it is impossible to refute the evidence.
- **For example,** someone might deny sending an email message but the message system adds a timestamp and digital signs the message with the message originator's digital signature.

Security Services- Access control

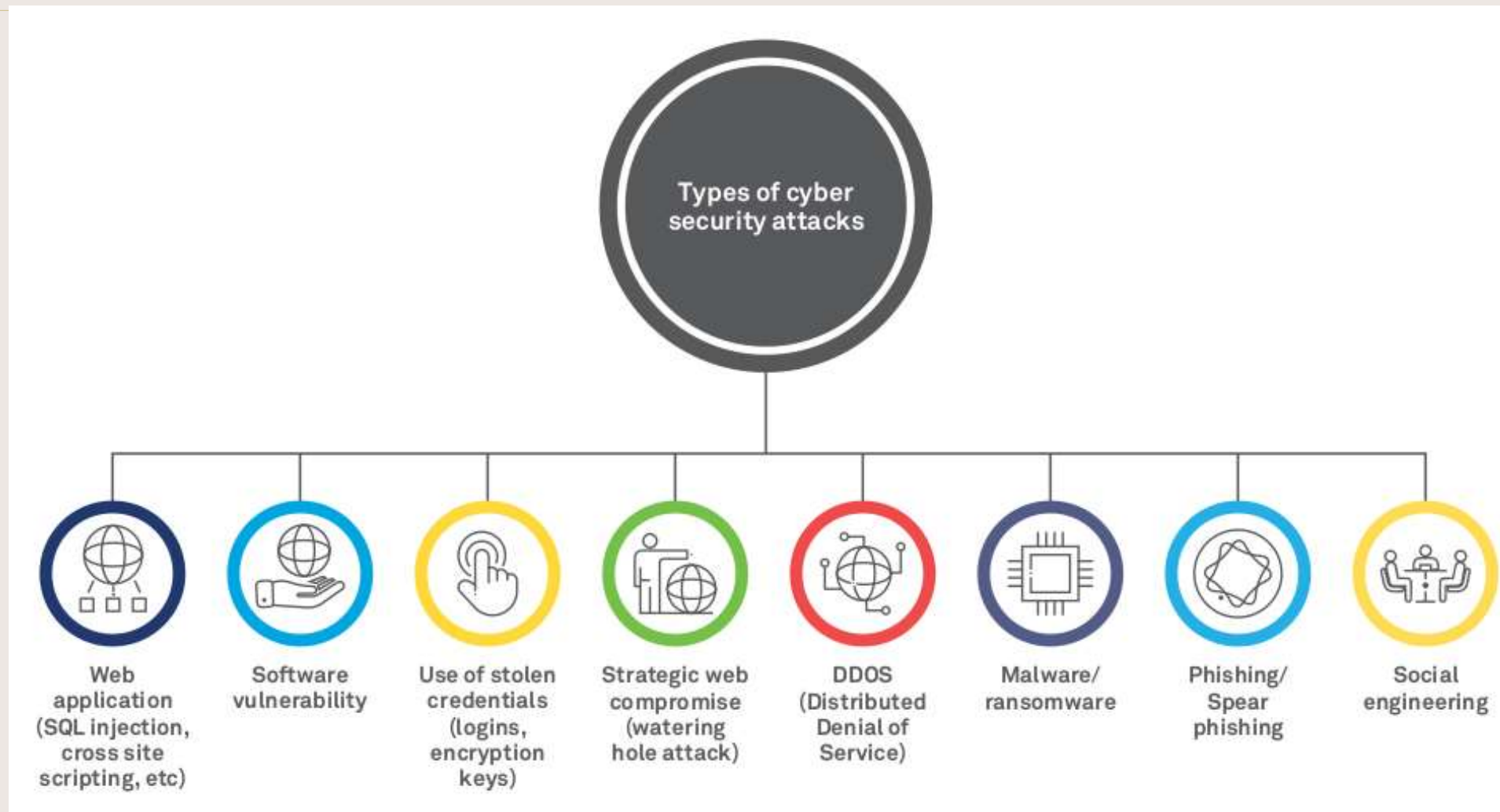
- **Access control** involves the use of policies and procedures to determine who is allowed to access specific resources within a system.
- **Authorization:** Authorization places restrictions on the actions of authenticated users.
- **For example,** Bob can't look at Charlie's account balance or install new accounting software on the AOB system.
- Since authentication and authorization both deal with issues of access to resources. (**Access Control**)

Threat & Vulnerability

- **Threat:** Threat is an object, person or any other entity that can potentially cause damage to the organization, IT Systems or network.
- **Vulnerability:** A weakness in the organization, IT Systems, or network that can be exploited by a threat.
- Sources of threats are external hackers, internal hackers, poorly trained persons etc.
- **Examples:** System hacking, Backdoors, Fraud, Poor documentation, Letter bombs, Viruses, Denial of service, Corruption of data, Malicious code, introduction System, bugs etc.



Common Types of Cyber Security Attacks



SQL injection attack

- SQL injection is a code injection technique that might destroy your database.
- SQL injection is one of the most common web hacking techniques.
- SQL injection is the placement of malicious code in SQL statements, via web page input.
- A successful SQL injection attack can result in unauthorized access to sensitive data, such as passwords, credit card details, or personal user information.

Eavesdropping Attack

- Eavesdropping attack also referred to as **sniffing or snooping attack** is a major concern when comes to cyber security.
- Through these attacks, your information like passwords, card details, and other sensitive data is easily stolen while it is getting transferred from one device to another.
- **Data encryption is the best countermeasure for eavesdropping.**

Denial-of-service (DoS) Attacks

- Denial of Service (DoS) is a cyber-attack on an individual Computer or Website with the intent to deny services to intended users. Their purpose is to disrupt an organization's network operations by denying access to its users.
- Attackers in these types of attacks typically flood web servers, systems or networks with traffic that overwhelms the victim's resources and makes it difficult or impossible for anyone else to access them.

Malware

Malware:

- **Malware**—short for "**malicious software**"—is any software code or computer program intentionally written to harm a computer system or its users.
- Almost every modern cyberattack involves some type of malware. These malicious programs can take many forms, ranging from highly damaging and costly ransomware to merely annoying adware, depending on what cybercriminals aim to do.
- **Example:** computer viruses, worms, trojan horses, bots, spyware, adware, etc.

Malware

Internet bot:

- also known as **web robots**, are automated internet applications controlled by software agents
- These bots interact with network services intended for people, carrying out monotonous tasks and behaving in a humanlike manner (i.e., computer game bot)
- Bots can gather information, reply to queries, provide entertainment, and serve commercial purposes.

Malware

Adware:

- **Advertising-supported software** is any software package which automatically plays, displays, or downloads advertising material to a computer after the software is installed on it or while the application is being used.
- Adware is software integrated into or bundled with a program, typically as a way to recover programming development costs through advertising income

Malware

Spyware:

- A Spyware program sends info from the infected computer to the person who initiated the spyware program on your computer
- Spyware can collect many different types of information about a user:
 - Records the types of websites a user visits
 - Records what is typed by the user to intercept passwords or credit card numbers
 - Used to launch “pop up” advertisements

Malware

Spam:

- **Spamming** is the abuse of electronic messaging systems to send unsolicited, undesired bulk messages
- Spam media includes:
 - e-mail spam (most widely recognized form)
 - instant messaging spam
 - Usenet newsgroup spam
 - Web search engine spam
 - spam in blogs
 - mobile phone messaging spam

Other Malware attacks

- **Virus** is a computer program that attaches itself to an executable file or application. It can replicate itself, usually through an executable program attached to an e-mail.
- **File infectors** — File infector viruses usually attach themselves to executable code, such as .exe files.
- **Trojans** — A Trojan or a Trojan horse is a program that hides in a useful program and usually has a malicious function. A major difference between viruses and Trojans is that Trojans do not self-replicate.
- **Worms** — A worm is a computer program that replicates and propagates itself without having to attach itself to a host. Most infamous worms are Code Red and Nimda. Worms differ from viruses in that they do not attach to a host file,
- **Ransomware** — Ransomware is a type of malware that blocks access to the victim's data and threatens to publish or delete it unless a ransom is paid. .

Phishing

Phishing:

- A criminal activity using social engineering techniques.
- An attempt to acquire sensitive data, such as passwords and credit card details, by masquerading as a trustworthy person or business in an electronic communication.
- Typically carried out using email or an instant message

Sniffers and Social Engineering

- **Sniffers** - a program and/or device that can monitor data traveling over a network. Sniffers can be used both for legitimate network management functions and for stealing information from a network.
- **Social Engineering** - within the context of information security, the process of using social skills to convince people to reveal access credentials or other valuable information to the attacker.

5 Types of Cyber Criminals



The
Social Engineer



The
Spear Phisher



The Hacker



The
Rogue Employee



The
Ransom Artist

Types of Cyber Criminals

- **The Social Engineer:** Cyber criminals pretending to be someone else can trick unsuspecting employees to compromise data.
- **The Spear Phisher:** Social threats factored into just under one-third of confirmed data breaches, with phishing the tactic used in 92 percent of social-related attacks.
- **The Hacker:** Nearly two-thirds of confirmed data breaches involved leveraging weak, default or stolen passwords. Malware poses a serious threat, as it can capture keystrokes from an infected device even if employees use strong passwords with special characters and a combination of upper- and lower-case letters.
- **The Rogue Employee:** Unhappy employees present an insider threat to data.
- **The Ransom Artist:** Bad actors have been modifying codes and implementing new ransom attack methods

Why is Cyber Security Important?

- Unauthorized access (malware, spyware) limits our ability to protect the confidentiality of the data
- Malicious programs can alter the data values, destroying the integrity of the data
- Denial of Service (DoS) attacks can shut down a server and/or network, making the system unavailable.

Why is it Important?

- Reputation loss
- Financial loss
- Intellectual property loss
- Legislative Breaches leading to legal actions (Cyber Law)
- Loss of customer confidence
- Business interruption costs

What Can We Do?

- **Security Assessment**
 - Identify areas of risk
 - Identify potential for security breaches, collapses
 - Identify steps to mitigate
- **Security Application**
 - Expert knowledge (train, hire, other)
 - Multi-layered Approach (there is no single solution)
 - Policies and Procedures
- **Security Awareness**
 - Security Training at all levels (external and/or internal)
 - Continuing education and awareness – not a one-time shot!
 - Make it part of the culture